

Security Review and Remediation Report

BharatOne retailer platform - mybharatone.com

Report date	7 August 2026	Version	1.0
Platform	mybharatone.com	Classification	Confidential
Prepared by	BharatOne engineering	Review type	Internal - not an independent audit

1. Summary

Concerns were raised about the security of the BharatOne platform. Those concerns were well founded. A full review was carried out on 6 and 7 August 2026 and identified **sixteen issues**, of which two were critical and three were high severity.

Fifteen of the sixteen are now closed. Each fix was verified by measurement against the live system rather than by inspection of the code, and the before and after figures are given for every finding in section 4. The remaining item is low severity and its status is stated plainly in section 5, together with four operational actions that are outstanding.

The two critical findings deserve to be named directly. First, 2,429 identity documents - Aadhaar cards, PAN cards, selfies and KYC videos belonging to retailers and their customers - were readable by anyone on the internet with no login. Second, two email endpoints could be called by anyone, allowing a stranger to send messages from the BharatOne domain, to any address, carrying any link, under subject lines such as "Your BharatOne account is approved - login details inside".

Neither issue shows evidence of having been exploited, and no data loss has been identified. Both are closed.

Severity	Found	Closed	Open
Critical	2	2	0
High	3	3	0
Medium	7	7	0
Low	4	3	1
Total	16	15	1

2. Scope and method

The review covered the public website, all twelve portals, the PostgreSQL database and its row-level security policies, object storage, and all thirty-four server-side functions.

Findings were established by **impersonating each class of user against the live database** and recording what they could actually reach - an anonymous visitor, a retailer, each staff role, and a staff member holding a valid password who had not completed two-factor authentication. Every remediation was re-tested the same way. Where a change carried risk of locking users out, it was first rehearsed inside a transaction that was rolled back, and the rehearsal output is quoted in the migration that applied it.

This was an internal review. It was performed by the same party that built the platform and is therefore not independent. Section 7 addresses that limitation.

3. Findings at a glance

#	Finding	Severity	Evidence: before to after	Status
1	Identity documents in object storage readable without authentication	Critical	2,429 files readable by anyone to 0	Closed
2	Unauthenticated email endpoints permitting messages from the BharatOne domain to any recipient	Critical	2 endpoints open to the internet to staff-authenticated only	Closed
3	Privileged database functions callable without authentication	High	282 callable anonymously to 27, all intentionally public	Closed
4	Two-factor authentication enforced in the browser only, not at the interface layer	High	235 registrations and 8 wallets readable without a code to 0	Closed
5	Configuration table readable by the public, including a password hash and commercial terms	High	28 of 28 rows public to 7, all already published on the website	Closed
6	Legacy account lookup returning personal data with no password check	Medium	725 accounts exposed by a redundant function to function removed	Closed
7	Username enumeration across legacy accounts	Medium	Unlimited attempts to 20 per address per 10 minutes	Closed
8	Support attachment storage configured as public	Medium	Public bucket, 0 files present to private with signed access	Closed
9	Internal planning board on the public site behind a browser-side password	Medium	13 MB and 122 internal screenshots public to admin plus 2FA only	Closed
10	Server-side proxy attaching a third-party API key with no caller check	Medium	Open to the internet to signed-in callers only	Closed
11	Notification endpoint usable as an unauthenticated mail relay to administrators	Medium	Any body accepted to one-time token required	Closed
12	Payment gateway configuration readable by the public	Medium	Readable by anyone to signed-in users only	Closed
13	Role-check function callable anonymously	Low	Anyone could ask whether an account was an administrator to refused	Closed
14	Account suspension control had no effect	Low	Suspended users could still sign in to sessions ended, sign-in refused	Closed
15	A settings screen displayed two-factor status that was not read from the account	Low	Displayed enabled on an account with none to live status	Closed
16	Scheduled health scan triggerable by anyone	Low	Open to the internet to shared-token gate; see section 5	Open

4. The five most serious findings in detail

4.1. Identity documents readable without authentication

Severity: Critical

What was found. The object storage bucket holding retailer KYC material carried a policy granting read access to the anonymous role. The bucket contained 2,429 files: Aadhaar cards, PAN cards, passport photographs, shop photographs, selfies and video KYC recordings. A second policy also permitted anonymous overwriting of those files.

Why it mattered. Any person on the internet who knew or guessed a file path could retrieve identity documents belonging to retailers and, in many cases, their customers. This is personal data of the most sensitive kind.

What was changed. Both policies were removed and replaced with one that admits a retailer to their own documents only, across the three folder layouts in historical use. A naive removal would have cut off 44 of 59 retailers from their own records; the replacement was written against the live data to avoid that.

Verification. Measured after the change: an anonymous visitor reaches 0 of 2,429 files. A sample retailer reaches exactly their own 7. Review staff retain full access. All 59 retailers retain access to every one of their own documents.

4.2. Unauthenticated email endpoints

Severity: Critical

What was found. Two server functions accepted requests with no authentication and took the recipient address, the display name and the destination link directly from the request. One sends approval credentials; the other requests KYC re-uploads.

Why it mattered. A stranger could cause the BharatOne mail server to send, from the BharatOne domain, a message reading "Your BharatOne account is approved - login details inside" or "Action needed: re-upload your KYC document(s)", to any address, carrying any link. This is a credential- and document-harvesting capability using the company's own reputation and infrastructure.

What was changed. Both endpoints now require a caller holding a staff role. Both are reached only from the registration review screen, which is staff-only, so no legitimate use is affected.

Verification. Deployed as versions 25 and 25 respectively. Unauthenticated requests are refused with HTTP 401 before the request body is read.

4.3. Privileged functions callable without authentication

Severity: High

What was found. 282 database functions carrying elevated privileges were executable by the anonymous role, including password reset, wallet movement and administrative operations. The cause was a PostgreSQL default that grants execution to PUBLIC unless it is explicitly revoked.

Why it mattered. The interface key is embedded in the website's JavaScript by design, so anonymous execution means execution by anybody.

What was changed. Execution was revoked from PUBLIC across the schema and re-granted only where a role legitimately requires it. Default privileges were altered so newly created functions do not reopen the same gap.

Verification. Reduced from 282 to 27. Of those 27, 21 are internal routines of a text-search extension and the remainder are endpoints that must be public: registration, one-time password verification, application tracking and postcode lookup.

4.4. Two-factor authentication not enforced at the interface layer

Severity: High

What was found. Two-factor authentication was enforced by the browser application. The database granted access on the basis of the account's role and never asked whether the session had presented a code.

Why it mattered. The control stopped a curious member of staff and did not stop the attacker it exists for: somebody holding a stolen staff password who uses the interface directly and never loads the company's JavaScript.

What was changed. A session-assurance check was added to the two functions through which every privileged decision already passes, covering 184 policies with two changes and leaving no policy able to be forgotten. Sessions belonging to users who hold no authenticator are unaffected, so nobody is locked out of the screen that enrolls them.

Verification. Measured with a session that authenticated by password alone: 235 registrations and 8 wallets before, 0 and 0 after. The same account, having presented its code, retains full access. Seven scenarios including scheduled jobs and server-to-server calls were rehearsed in a transaction that was rolled back before the change was applied.

4.5. Configuration table readable by the public

Severity: High

What was found. The application configuration table carried a policy permitting the anonymous role to read every row. Among the 28 rows were an unsalted SHA-256 hash of an internal passphrase, internal alert email addresses, a staff login name, and the AePS commission split, registration fee and money-transfer limits.

Why it mattered. An unsalted hash of a human-chosen passphrase is recoverable offline in seconds, so publishing it approximates publishing the passphrase. The commercial terms were readable by any competitor.

What was changed. Anonymous read was narrowed to the seven values the logged-out website genuinely needs, all of which are already printed on the public site. The passphrase hash is now unreadable by everyone except administrators, and is no longer referenced by any code.

Verification. Anonymous callers now read 7 of 28 keys. The registration page continues to display the correct fee. The affected passphrase should be treated as compromised and changed.

5. Outstanding items

The following are not yet complete. They are listed here rather than omitted, because a report that conceals its gaps is worthless the moment a reader finds one.

Item	Severity	Status and owner
Rotation of a source-control access token and payment-partner API keys	High	Not started. BharatOne management. This is the largest remaining exposure: the credentials are valid and have been handled during development.
Breached-password screening at sign-up and password change	Medium	Available but not enabled. A single setting in the authentication provider. BharatOne management.
Staff enrolment in two-factor authentication	Medium	Enforcement is live and verified for all 19 staff accounts. 1 of 19 has enrolled. The protection does not exist for an individual until they enrol.
Finding 16: shared-token gate on the scheduled health scan	Low	Database side applied and live; the function deployment is pending. No data exposure and no financial exposure; the issue is unauthenticated triggering of outbound checks.

6. How to verify these claims independently

Every statement in section 3 can be reproduced by a technical reviewer holding the public interface key, which is embedded in the website and requires no privileged access.

Claim	How to check it
Identity documents are no longer public	Request any known KYC object path with the public key and no session. Expect a refusal rather than a file.
The database is not open	Query retailer registrations, profiles, wallets, transactions and support tickets with the public key and no session. Expect zero rows from each. Row-level security is enabled on every table in the public schema without exception.
Email endpoints are closed	Post to the credentials and document-request endpoints without an authorisation header. Expect HTTP 401.
Two-factor is enforced beyond the browser	Authenticate an enrolled staff account by password alone, without presenting a code, and query registrations directly. Expect zero rows.
Configuration is no longer public	Read the settings table with the public key. Expect seven keys, all of which already appear on the public website.

7. Recommendation and limitations

This review was not independent. It was carried out by the party that built the platform. That is a real limitation and no amount of measurement removes it: the same assumptions that produced a defect can hide it from its author.

An independent penetration test is recommended, by a firm with no involvement in building the system. The findings above give such a firm a starting point rather than a conclusion. Where a client requires assurance for a commercial or regulatory purpose, an external report is the appropriate instrument and this document is not a substitute for one.

Two matters fall outside the scope of this review and should be addressed separately. The first is the outstanding credential rotation in section 5, which is an operational task rather than a code change. The second is the platform's use of third-party and government programme branding, which is a legal question for qualified counsel and is not a security matter.

Prepared 7 August 2026. Figures in this report were measured against the production system on 6 and 7 August 2026 and are accurate as at that date.